

Lab 5

Sniffing and Session Hijacking

Part 1: Wireshark for network monitoring

- 1) Run the Wireshark and analyze a Ping Packet (send a ping packet to Google)

Capturing from eth0

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

http

No.	Time	Source	Destination	Protocol	Length	Info
2448	696.724893340	192.168.64.2	65.61.137.117	HTTP	425	GET /style.css HTTP/1.1
2454	696.749920381	65.61.137.117	192.168.64.2	HTTP	1544	HTTP/1.1 200 OK (text/css)
2466	696.750143051	192.168.64.2	65.61.137.117	HTTP	488	GET /images/pf_lock.gif HTTP/1.1
2467	696.750186085	192.168.64.2	65.61.137.117	HTTP	486	GET /images/home2.jpg HTTP/1.1
2468	696.750217121	192.168.64.2	65.61.137.117	HTTP	485	GET /images/logo.gif HTTP/1.1
2469	696.750237160	192.168.64.2	65.61.137.117	HTTP	486	GET /images/home1.jpg HTTP/1.1
2470	696.750278444	192.168.64.2	65.61.137.117	HTTP	491	GET /images/header_pic.jpg HTTP/1.1
2471	696.750298899	192.168.64.2	65.61.137.117	HTTP	486	GET /images/home3.jpg HTTP/1.1
2472	696.779565755	65.61.137.117	192.168.64.2	HTTP	8214	HTTP/1.1 200 OK (JPEG JFIF image)
2484	696.781013965	65.61.137.117	192.168.64.2	HTTP	1738	HTTP/1.1 200 OK (JPEG JFIF image)
2485	696.781014006	65.61.137.117	192.168.64.2	HTTP	366	HTTP/1.1 200 OK (GIF89a)
2486	696.781014048	65.61.137.117	192.168.64.2	HTTP	4850	HTTP/1.1 200 OK (JPEG JFIF image)
2494	696.781037252	65.61.137.117	192.168.64.2	HTTP	5302	HTTP/1.1 200 OK (GIF89a)
2501	696.781597448	192.168.64.2	65.61.137.117	HTTP	489	GET /images/gradient.jpg HTTP/1.1
2504	696.804166369	65.61.137.117	192.168.64.2	HTTP	3421	HTTP/1.1 200 OK (JPEG JFIF image)
2511	696.806609910	65.61.137.117	192.168.64.2	HTTP	1266	HTTP/1.1 200 OK (JPEG JFIF image)

Frame 2289: Packet, 655 bytes on wire (5240 bits), 655 bytes captured (5240 bits) on interface eth0, capture length 655 bytes
 Ethernet II, Src: d2:a3:ee:59:8b:e1 (d2:a3:ee:59:8b:e1), Dst: 6a:5e:0b:54:5a:50
 Internet Protocol Version 4, Src: 192.168.64.2, Dst: 65.61.137.117
 Transmission Control Protocol, Src Port: 32934, Dst Port: 80, Seq: 1029, Win: 65535, Len: 552
 Hypertext Transfer Protocol (http), 552 bytes

Packets: 2534 · Displayed: 44 (1.7%) | Profile: Default

Capturing from eth0

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

icmp

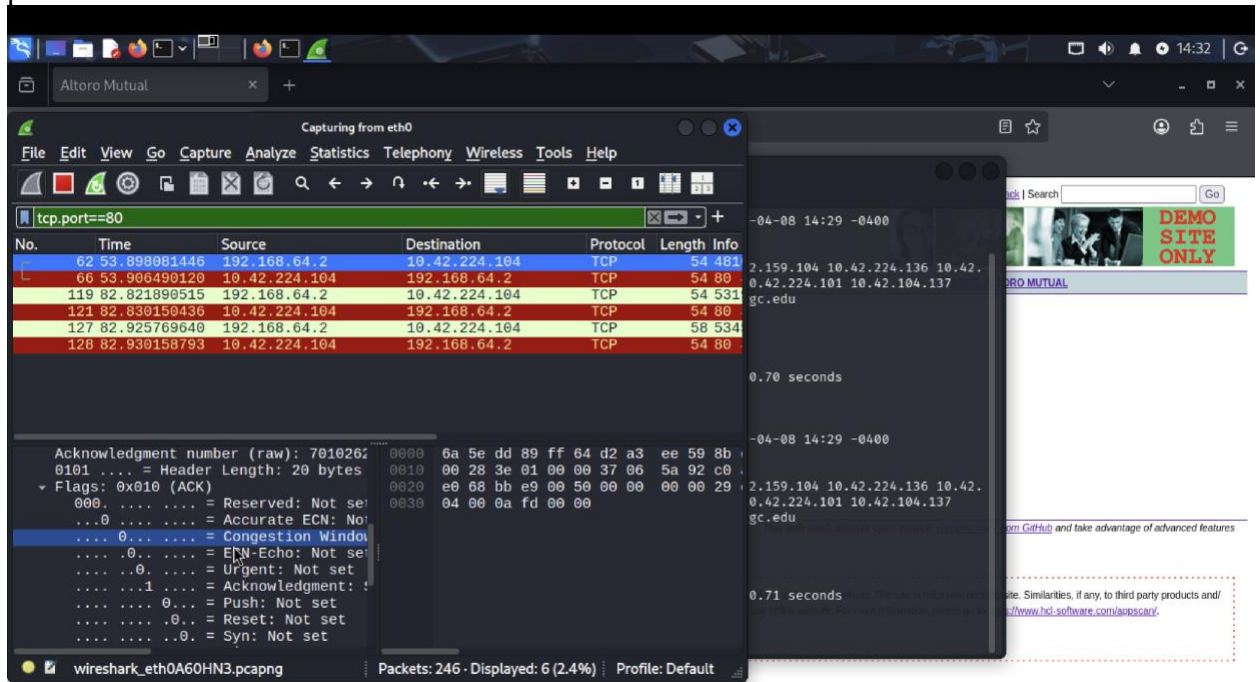
No.	Time	Source	Destination	Protocol	Length	Info
56	88.502649520	192.168.64.2	8.8.8.8	ICMP	98	Echo (ping) request
57	88.508413928	8.8.8.8	192.168.64.2	ICMP	98	Echo (ping) reply
58	89.503605741	192.168.64.2	8.8.8.8	ICMP	98	Echo (ping) request
59	89.513743300	8.8.8.8	192.168.64.2	ICMP	98	Echo (ping) reply
60	90.506555900	192.168.64.2	8.8.8.8	ICMP	98	Echo (ping) request
61	90.516346612	8.8.8.8	192.168.64.2	ICMP	98	Echo (ping) reply
62	91.510139687	192.168.64.2	8.8.8.8	ICMP	98	Echo (ping) request
63	91.519830646	8.8.8.8	192.168.64.2	ICMP	98	Echo (ping) reply

Frame 56: Packet, 98 bytes on wire (784 bits), 98 bytes captured (784 bits) on interface eth0, capture length 98 bytes
 Ethernet II, Src: d2:a3:ee:59:8b:e1 (d2:a3:ee:59:8b:e1), Dst: 08:00:27:28:2a:2b
 Internet Protocol Version 4, Src: 192.168.64.2, Dst: 8.8.8.8
 Internet Control Message Protocol

Internet Control Message Protocol: Protocol | Packets: 356 · Displayed: 8 (2.2%) | Profile: Default

2) Repeat the above with destination system (your Host machine OS)

- 3) Use NMAP (on Kali) and scan your Host machine OS. Demonstrate/detect the scanning packets.



- 4) Demonstrate the Sniffing using HTTP protocol and present session ID and Parameters

The screenshot displays the Burp Suite interface with the 'http' tab selected. The top pane shows a list of captured HTTP requests. The bottom pane provides a detailed view of the selected request (No. 63).

No.	Time	Source	Destination	Protocol	Length	Info
38	3.027657095	192.168.64.2	65.61.137.117	HTTP	638	GET /login.jsp HTTP/1.1
41	3.051920149	65.61.137.117	192.168.64.2	HTTP	8796	HTTP/1.1 200 OK (text/html)
63	9.689351719	192.168.64.2	65.61.137.117	HTTP	826	POST /doLogin HTTP/1.1 (application/x-www-form-urlencoded)
64	9.619268341	65.61.137.117	192.168.64.2	HTTP	192	HTTP/1.1 302 Found
66	9.620560655	192.168.64.2	65.61.137.117	HTTP	685	GET /login.jsp HTTP/1.1
67	9.645161243	65.61.137.117	192.168.64.2	HTTP	8899	HTTP/1.1 200 OK (text/html)

The detailed view of the selected request (No. 63) shows the following headers and body:

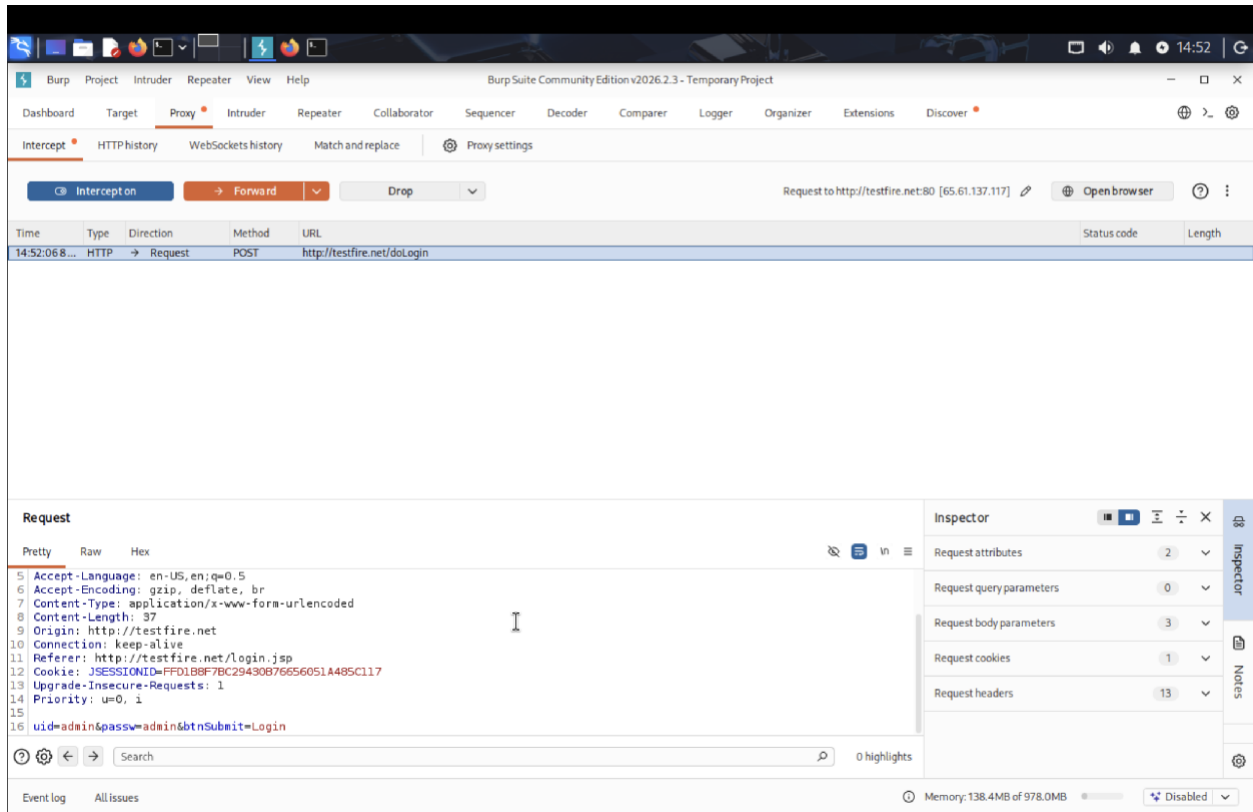
```

Accept-Encoding: gzip, deflate\r\n
Content-Type: application/x-www-form-urlencoded\r\n
Content-Length: 37\r\n
Origin: http://altoro.testfire.net\r\n
Connection: keep-alive\r\n
Referer: http://altoro.testfire.net/login.jsp\r\n
Cookie: JSESSIONID=AE1DF7AA02A1FFD0A6B09424E618E75B; AltoroAccount=...
Upgrade-Insecure-Requests: 1\r\n
Priority: u=0, i\r\n
[Response in frame: 64]
Full request URI: http://altoro.testfire.net/doLogin
File Data: 37 bytes
HTML Form URL Encoded: application/x-www-form-urlencoded
  Form item: "uid" = "admin"
  Form item: "passw" = "admin"
  Form item: "btnSubmit" = "Login"
  
```

The bottom status bar indicates: Packets: 2045 - Displayed: 6 (0.3%) Profile: Default

Part 2: Demonstrate the Session Hijacking attack using Burp suite

Configure the Burp suite and demonstrate the interception of the session (Paste the screenshot)

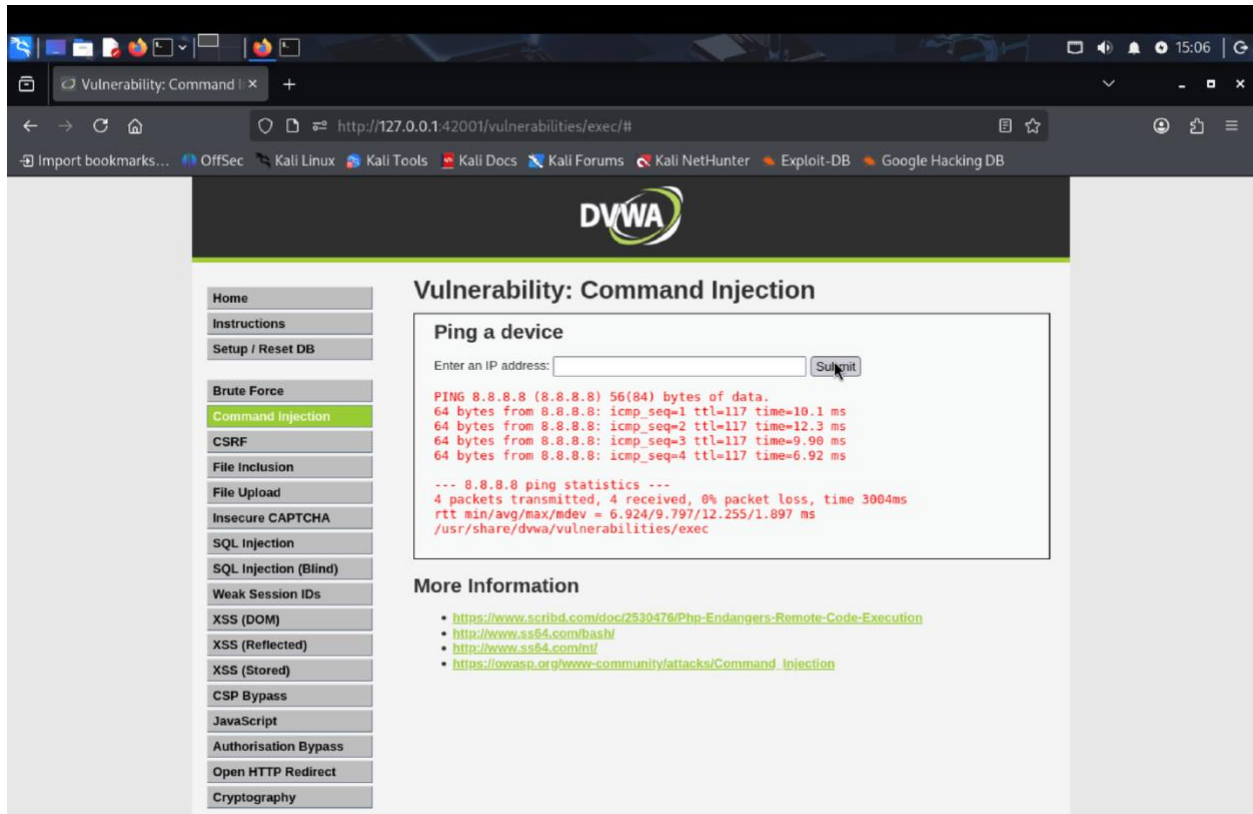


Part 3: Web Application attacks on DVWA: (Use DVWA and demonstrate the following attacks)

1. With **Low security**, Use command Injection module
 - a. list the directory
 - b. print the working directory
 - c. Display the home directory

Please discuss the vulnerability (One line)

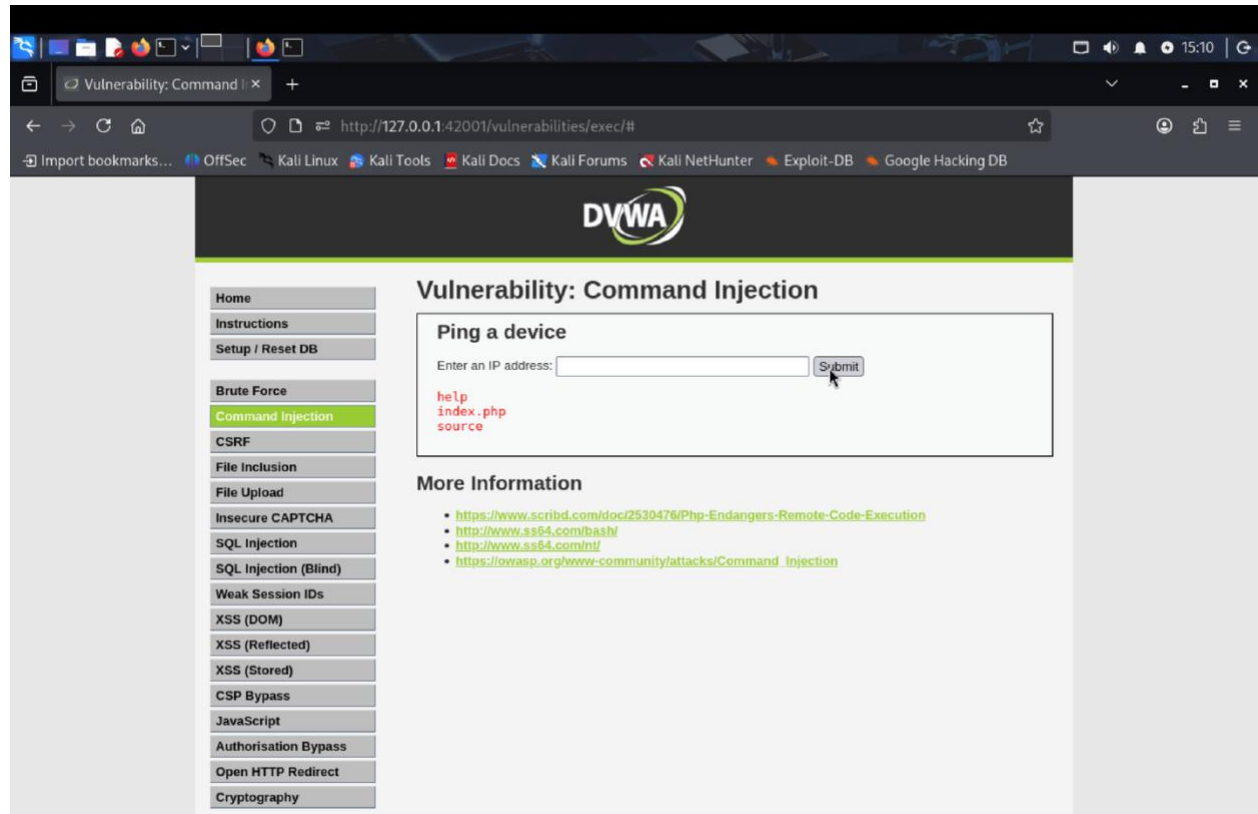
8.8.8.8 && ls



2. With **Medium** security, Use command Injection module

- list the directory
- print the working directory
- Display the home directory

8.8.8.8 | ls



Please discuss the vulnerability (One line)

Non

Black listing

3. With **Low security**, Use file inclusion (directory Traversal)
 - a. Display robots.txt
 - b. Display Php information
 - c. Passwords configurations

Vulnerability: Command

PHP 8.4.16 - phpinfo()

http://127.0.0.1:42001/vulnerabilities/fi/?page=../phpinfo.php

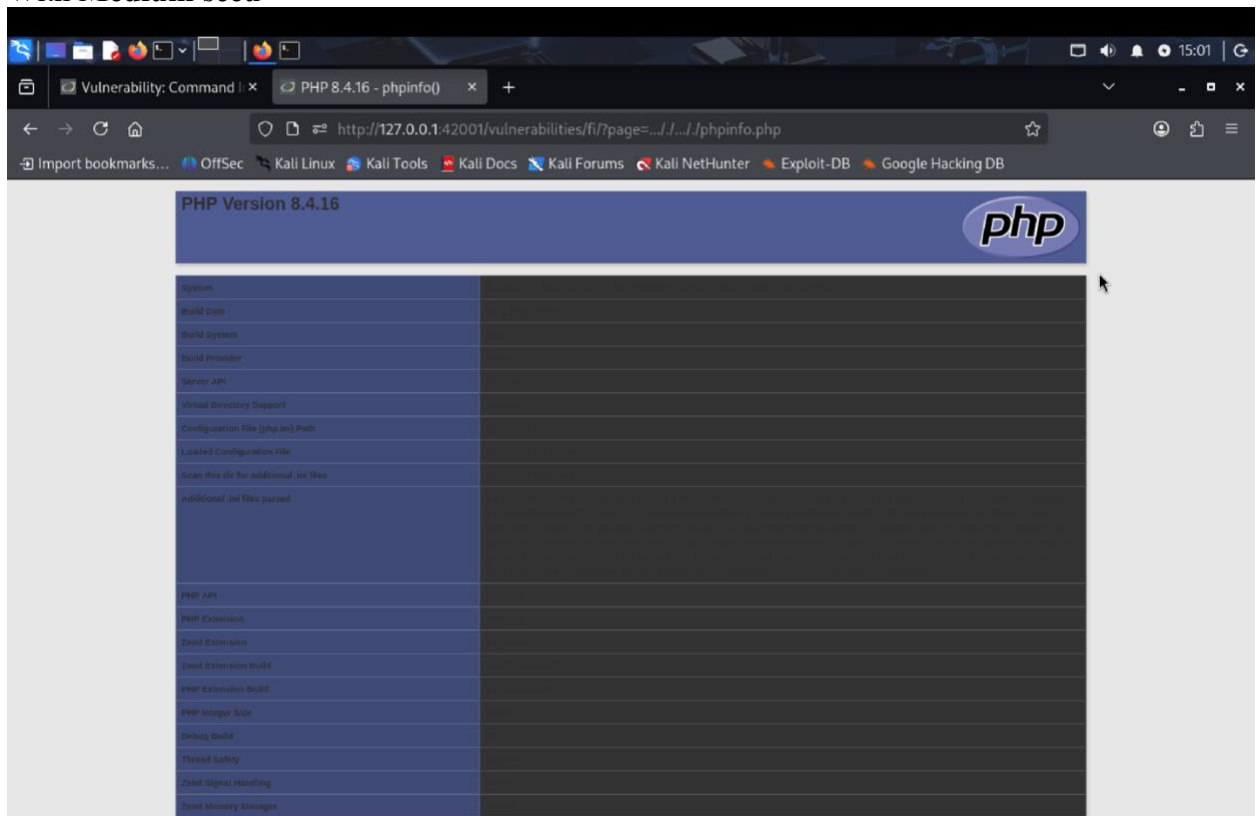
Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

PHP Version 8.4.16



System	
Build Date	
Build System	
Build Provider	
Server API	
Virtual Directory Support	
Configuration File (php.ini) Path	
Loaded Configuration File	
Scan this dir for additional .ini files	
Additional .ini files parsed	
PHP API	
PHP Extension	
Zend Extension	
Zend Extension Build	
PHP Extension Build	
PHP Image Size	
Default charset	
Thread Safety	
Default signal handling	
Zend Memory Manager	

4. With Medium secu



ity, Use file inclusion (directory Traversal)

a. Display robots.txt

[illegible]

Passwords configurations

**ure Burp suite and demonstrate the Brute force Attack
(discuss your finding and methodology)**

